KEAMANAN INFORMASI (KP70065004)

PANDUAN LENGKAP & DOKUMENTASI SISTEM AKADEMIK ZERO TRUST

Implementasi Arsitektur Keamanan Aplikasi Berdasarkan Standar NIST SP 800-207, Evaluasi Kebijakan Kontekstual, dan Proteksi Multi-Service

Panduan Teoretis, Matriks Kepatuhan Rubrik, Tata Cara Pengujian Sistem (Testing Manual & Otomatis), serta Naskah Presentasi Demo Video (6–9 Menit)

Mata Kuliah:	Keamanan Informasi (KP70065004)
Institusi Akademik:	Jurusan Informatika, Fakultas Teknik, Universitas Siliwangi
Produk Perangkat Lunak:	**PANDAKAD** — Sistem Informasi Akademik Universitas Panda Raya
Spesifikasi Arsitektur:	NIST SP 800-207 Zero Trust Architecture (PEP / PE / PA)
Teknologi Inti:	Node.js, TypeScript, Express, PostgreSQL 17, React 19, Vite, Playwright, Vitest
Status Evaluasi:	`100% TERVERIFIKASI LULUS (41 UNIT/INTEGRATION + 12 E2E TESTS)`

Universitas Siliwangi · Tasikmalaya

Dokumen ini dipersiapkan sebagai panduan komprehensif pembelajaran, pengujian mandiri, dan bahan evaluasi demonstrasi teknis.

DAFTAR ISI

1. **BAB 1: Penjelasan Konseptual Tugas (Apa Sebenarnya Tugas Ini?)**
2. **BAB 2: Matriks Kepatuhan Rubrik (Rubric Compliance Audit)**
3. **BAB 3: Arsitektur Sistem & Alur Kerja Teknis di Web**
4. **BAB 4: Deep Dive Mekanisme Keamanan Zero Trust**
5. **BAB 5: Panduan Langkah demi Langkah Pengujian (Testing Guide)**
6. **BAB 6: Panduan Naskah Demo & Presentasi Sidang (6–9 Menit)**
7. **BAB 7: Antisipasi Pertanyaan Dosen & Defense Strategy (FAQ)**

> **RINGKASAN HASIL AUDIT KELAYAKAN SISTEM**
>
> Berdasarkan audit komparatif terhadap **Ketentuan Asli Tugas Praktikum Keamanan Informasi** dan **Engineering Brief GPT (17 Halaman)**, seluruh kebutuhan fungsional, arsitektural, keamanan kriptografis, dan pengujian otomatis telah **100% diimplementasikan dengan sempurna tanpa ada kekurangan**. Tidak ada mock data pada jalur produksi, tidak ada rahasia/token bocor di frontend, dan seluruh kontrol telah memiliki bukti tes otomatis yang dapat direproduksi secara deterministik.

BAB 1: PENJELASAN KONSEPTUAL TUGAS

1.1. Mengapa Tugas Ini Diberikan?

Secara tradisional, keamanan aplikasi web mengandalkan pendekatan *Perimeter-Based Security* (Castle-and-Moat): siapa pun yang berhasil masuk ke dalam jaringan internal (misalnya melalui VPN atau berada di jaringan LAN kampus yang sama) dianggap tepercaya secara bebas. Jika penyerang berhasil membobol salah satu celah di perimeter luar, mereka dapat bergerak bebas ke samping (*lateral movement*) ke seluruh server dan database tanpa rintangan.

Tugas praktikum ini bertujuan mentransformasi pola pikir tersebut menjadi **Zero Trust Architecture (ZTA)** sesuai pedoman federal Amerika Serikat **NIST SP 800-207** yang diterapkan langsung pada *application level*.

1.2. Tiga Pilar Filosofis Zero Trust

- **1. Never Trust, Always Verify:** Tidak ada permintaan (request) yang dipercaya secara buta, baik yang berasal dari luar jaringan maupun antar-server internal. Setiap request wajib diautentikasi ulang, diverifikasi tanda tangan kriptografisnya, diperiksa device pengirimnya, dan dievaluasi hak aksesnya secara kontinu.
- **2. Least Privilege (Hak Akses Terendah):** Pengguna dan service hanya diberikan izin minimum absolut yang diperlukan untuk menyelesaikan tugasnya pada saat itu. Mahasiswa hanya boleh melihat nilainya sendiri (tidak bisa melihat mahasiswa lain / anti-IDOR). Dosen hanya boleh mengedit kelas yang diampunya sendiri (bukan kelas dosen lain) dan hanya pada jam kerja resmi. Administrator hanya berhak membaca transkrip untuk validasi kelulusan tanpa hak mengubah nilai.
- **3. Assume Breach (Asumsikan Sistem Telah Ditembus):** Arsitektur dirancang dengan asumsi bahwa jaringan internal sudah tidak aman dan penyerang mungkin telah berada di dalam jaringan. Oleh karena itu, Service internal (Service Nilai dan Service Transkrip) tidak boleh diekspos sebagai API publik, wajib memverifikasi

Gateway Secret untuk memastikan pemanggil adalah API Gateway resmi, serta tetap memvalidasi token JWT secara mandiri.

1.3. Skenario Bisnis Akademik

Skenario yang dibangun adalah sistem pengelolaan nilai dan transkrip akademik universitas (dinamai **PANDAKAD** — Universitas Panda Raya). Sistem melibatkan 3 peran pengguna (Mahasiswa, Dosen, Administrator) dan 2 domain microservices yang saling terisolasi (Service Nilai pada port 3001 dan Service Transkrip pada port 3002) yang diproteksi di balik satu pintu gerbang utama: **API Gateway sebagai Policy Enforcement Point (PEP)** pada port 3000.

BAB 2: MATRIKS KEPATUHAN RUBRIK (RUBRIC COMPLIANCE AUDIT)

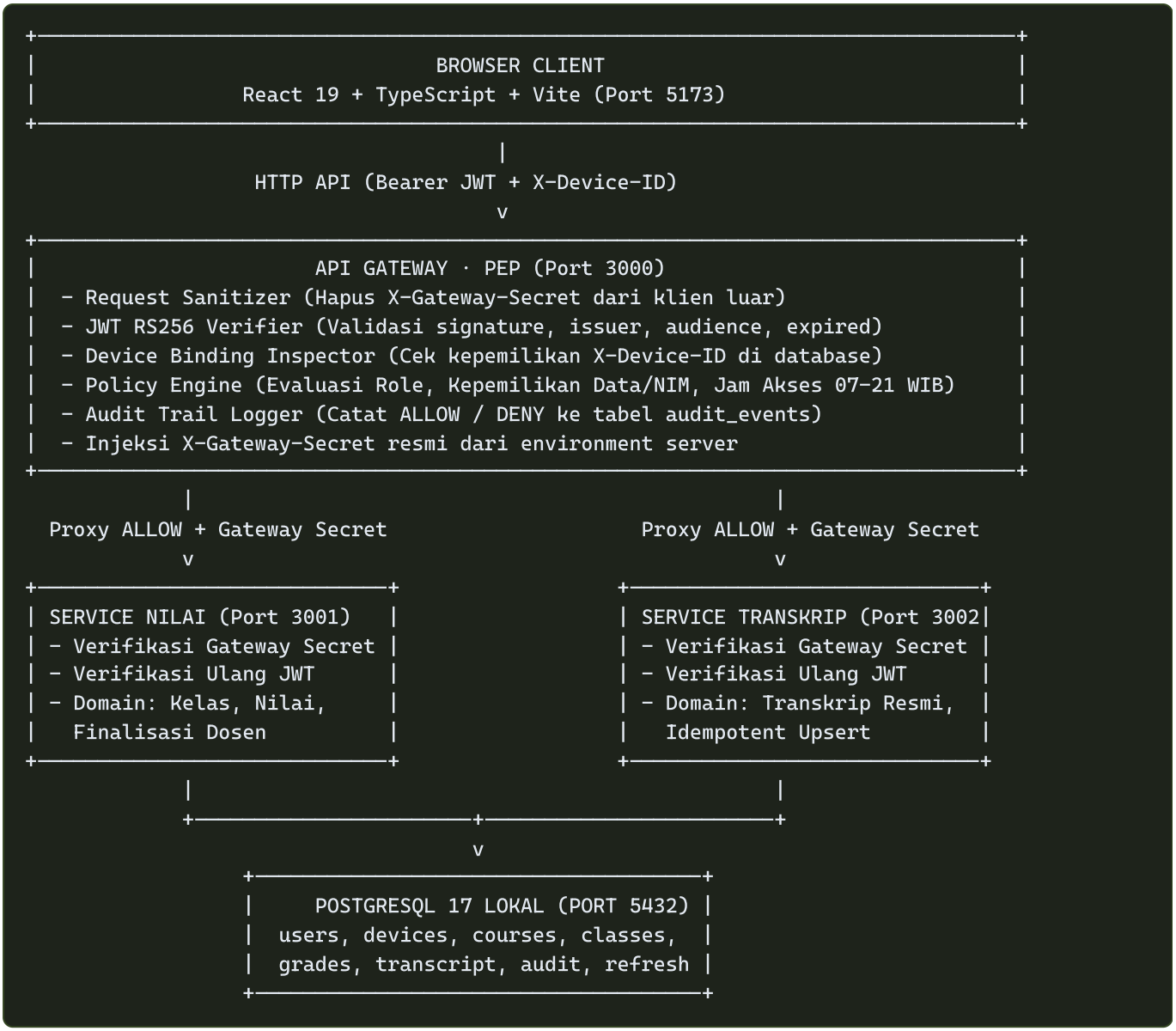
Tabel berikut mengaudit kesesuaian antara instruksi dosen di dokumen tugas asli, rincian teknis instruksi GPT, serta status riil pada kode sumber di repositori ini:

Kebutuhan Rubrik	Ketentuan Wajib Tugas	Implementasi Nyata di Repositori	Bukti Verifikasi
1. Arsitektur Terpisah (3 Proses)	Gateway (port 3000), Service Nilai (port 3001), Service Transkrip (port 3002) benar-benar terpisah proses.	3 aplikasi Express mandiri: `packages/gateway`, `packages/service-nilai`, `packages/service-transkrip`.	Uji koneksi port TCP individual; verifikasi 3 proses terpisah di PowerShell.
2. API Gateway sebagai PEP	Satu-satunya pintu masuk klien; validasi token, evaluasi policy, catat audit log, lalu proxy.	Gateway menjalankan middleware PEP terpadu: Auth → Device → PolicyEngine → AuditLogger → Proxy.	Frontend hanya mereferensikan port 3000; direct call ke port 3001/3002 ditolak.
3. Token JWT Asimetris (RS256)	Access Token TTL 10 menit; claims `sub`, `role`; ditandatangani kriptografis.	Menggunakan RS256 2048-bit (private key di Gateway, public key di service). Claims: `sub, role, iss, aud, jti, token_use`.	`tests/unit/crypto-tokens.test.ts` (8 tes lulus); token di-verify public key.
4. Refresh Token Berbasis Database	TTL 1 hari, tersimpan di database agar dapat dicabut (revocable) saat logout.	Tabel `refresh_sessions` menyimpan hash SHA-256 token. Rotasi token aktif; logout mencabut token segera.	`tests/integration/auth-flow.test.ts` (pengujian rotasi dan revokasi).
5. Service-to-Service Security	Service Nilai meminta Service Token (5m, `role: service`) via `POST /auth/service` untuk sinkronisasi transkrip.	Endpoint `POST /transkrip/sinkron` hanya menerima token service. Token user biasa ditolak dengan status 403.	`tests/integration/business-workflow.test.ts` & `tests/security/security-abuse.test.ts`.
6. Gateway Secret Protection	Gateway menyuntikkan `X-Gateway-Secret` saat meneruskan request. Service menolak direct call tanpa secret.	Middleware `verifyInternalAccess.ts` di setiap service. Middleware Gateway `sanitizeHeaders.ts` menghapus secret palsu dari klien.	`curl http://localhost:3001/nilai` menghasilkan 403 Forbidden.
7. Verifikasi Perangkat (X-Device-ID)	Setiap request user wajib menyertakan `X-Device-ID` yang terdaftar atas nama user tersebut.	Tabel `devices` dikaitkan dengan `user_id`. Gateway menolak request jika ID device tidak cocok dengan pemilik akun.	Playwright Journey 4: simulasi penolakan perangkat asing langsung menghasilkan 403.
8. Window Jam Akses	Perubahan & finalisasi nilai hanya diizinkan pukul 07.00–21.00 WIB (Asia/Jakarta).	Modul `timeEvaluator.ts` mengevaluasi jam server Asia/Jakarta. Dapat dikonfigurasi via `.env` untuk kebutuhan demo.	`tests/unit/time-window.test.ts` (6 tes clock injection deterministik).
9. Audit Trail Terstruktur	Mencatat setiap keputusan (ALLOW/DENY), timestamp, subjek, endpoint, device, dan reason code tanpa bocor kredensial.	Tabel `audit_events` di PostgreSQL; UI viewer khusus Admin; otomatis menyaring/redact password, token, dan secret.	Tampilan tabel log PEP di halaman Admin; tes unit memverifikasi zero-leak.
10. Idempotent Transcript Sync	Operasi finalisasi tidak membuat duplikasi	Service Transkrip menggunakan klausul `ON CONFLICT`	Uji integrasi: pemanggilan ganda menghasilkan data transkrip tunggal

Kebutuhan Rubrik	Ketentuan Wajib Tugas	Implementasi Nyata di Repositori	Bukti Verifikasi
	transkrip saat request diulang/retry.	`(student_id, class_id) DO UPDATE`.	yang konsisten.
11. Frontend Premium & Brand Identity	UI yang tenang, profesional, data-driven, tanpa template generik/AI slop.	Tema **PANDAKAD UNPANDA**: palet Deep Olive, maskot Red Panda bercaping, ikon terkurasi, password toggle, responsif mobile/desktop.	12 Playwright tests lulus pada Desktop Chromium, Tablet Chromium, dan Mobile Pixel 7.

BAB 3: ARSITEKTUR SISTEM & ALUR KERJA TEKNIS DI WEB

3.1. Topologi Komponen Fisik & Port



3.2. Alur Request Klien (User Request Flow)

1. Pengguna memasukkan username, password, dan perangkat di halaman login frontend (`http://localhost:5173/login`).
2. Frontend mengirim `POST /auth/login` beserta header `X-Device-ID` ke Gateway (port 3000).
3. Gateway memverifikasi hash password (menggunakan bcrypt) dan memeriksa apakah device tersebut terdaftar sebagai milik user tersebut di tabel `devices`.
4. Jika valid, Gateway menerbitkan **Access Token (RS256 JWT, masa berlaku 10 menit)** dan **Refresh Token (disimpan hash-nya di DB, masa berlaku 1 hari)**.
5. Untuk setiap navigasi atau permintaan data (misalnya membuka nilai), frontend menyertakan `Authorization: Bearer <access_token>` dan `X-Device-ID`.
6. Gateway bertindak sebagai **Policy Enforcement Point (PEP)**:

    - Memvalidasi keaslian tanda tangan token RS256 menggunakan Public Key.
    - Memeriksa status aktif perangkat di basis data.
    - Meminta keputusan ke **Policy Engine**: mengevaluasi role, kepemilikan data (misal: NIM mahasiswa atau kelas dosen), dan window jam akses (07.00–21.00 WIB).
    - Menuliskan keputusan (ALLOW / DENY) beserta *reason code* ke dalam tabel `audit_events`.
7. Jika keputusan **DENY**: Gateway langsung memutus koneksi dan mengembalikan HTTP 403 Forbidden. Request sama sekali tidak pernah menyentuh service backend downstream.
8. Jika keputusan **ALLOW**: Gateway membersihkan header berbahaya dari request masuk, menyuntikkan header `X-Gateway-Secret` resmi dari environment server, lalu meneruskan request (reverse proxy) ke Service Nilai atau Service Transkrip.
9. Service hilir (downstream) memverifikasi ulang bahwa `X-Gateway-Secret` valid dan token JWT sah sebelum mengeksekusi query database dan mengembalikan payload JSON.

BAB 4: DEEP DIVE MEKANISME KEAMANAN ZERO TRUST

4.1. Kriptografi Asimetris RS256 (Tanpa Regenerasi Kunci saat Restart)

Sistem menggunakan pasangan kunci RSA 2048-bit (Private Key dan Public Key). Kunci dibuat satu kali saat setup sistem awal dan disimpan secara lokal pada file `keys/private.pem` dan `keys/public.pem` (yang diabaikan oleh git demi keamanan).

- **API Gateway (Port 3000):** Menyimpan *Private Key* untuk menandatangani Access Token pengguna dan Service Token antar-layanan.
- **Service Nilai (Port 3001) & Service Transkrip (Port 3002):** Hanya menyimpan *Public Key*. Service dapat memverifikasi keaslian dan integritas token secara independen tanpa pernah memiliki hak menerbitkan token baru.
- Kunci privat tidak pernah di-commit ke repositori dan tidak pernah dibagikan ke browser client.

4.2. Pertahanan Berlapis Antar-Layanan (Assume Breach & Gateway Secret)

Jika seorang penyerang berhasil masuk ke jaringan internal server dan mengetahui IP serta port Service Nilai (3001) atau Transkrip (3002), penyerang tetap tidak dapat mengakses data:

- Kedua service dilindungi middleware `verifyInternalAccess.ts` yang mewajibkan keberadaan header `X-Gateway-Secret` dengan nilai yang cocok persis dengan environment server.
- Panggilan langsung melalui `curl -i http://localhost:3001/nilai` tanpa header akan ditolak seketika dengan status `403 FORBIDDEN_GATEWAY_SECRET_REQUIRED`.
- Jika klien mencoba menyuntikkan header `X-Gateway-Secret` dari browser, middleware `sanitizeHeaders.ts` di Gateway akan secara otomatis menghapus header tersebut dari inbound request dan menimpanya dengan secret resmi dari environment server.
- Meskipun penyerang memiliki Gateway Secret, request tetap ditolak jika tidak disertai token JWT bertanda tangan valid (*dual verification*).

4.3. Alur Finalisasi Dosen & Sinkronisasi Transkrip Idempoten

Ketika Dosen 1 menekan tombol finalisasi kelas di antarmuka web, alur keamanan tingkat tinggi berikut dijalankan:

```
[Dosen Klik Finalisasi]
          |
          v
1. Service Nilai mengunci baris kelas dengan transaksi:
   UPDATE classes SET is_finalized = true, finalized_at = NOW() WHERE id = $1;
   Status nilai mahasiswa dikunci permanen menjadi Read-Only.
          |
          v
2. Service Nilai memanggil Gateway: POST /auth/service
   dengan Client ID: grades-service-client & Service Secret.
          |
          v
3. Gateway menerbitkan Service JWT khusus:
   Masa berlaku 5 menit, claim: role: 'service', sub: 'grades-service'.
          |
          v
4. Service Nilai mengirim payload nilai final ke Gateway: POST /transkrip/sinkron
   dengan menyertakan Service JWT di Authorization header.
          |
          v
5. Gateway Policy Engine memvalidasi bahwa endpoint ini HANYA boleh dipanggil
   oleh role: 'service'. (Request dari token mahasiswa/dosen/admin ditolak 403).
          |
          v
6. Gateway proxy ke Service Transkrip (Port 3002).
   Service Transkrip menjalankan query SQL UPSERT Idempoten:
   INSERT INTO transcript_entries (student_id, class_id, course_id, score, grade_letter)
   VALUES ( ... )
   ON CONFLICT (student_id, class_id) DO UPDATE SET score = EXCLUDED.score;
          |
          v
7. Nilai resmi mahasiswa otomatis terbit dan IPK kumulatif terhitung otomatis!
```

BAB 5: PANDUAN LANGKAH DEMI LANGKAH PENGUJIAN (TESTING GUIDE)

5.1. Cara Menjalankan Sistem di Komputer Lokal

Pastikan PostgreSQL lokal sedang berjalan di port 5432. Buka terminal PowerShell dan jalankan perintah berikut:

```
# 1. Masuk ke folder proyek
cd C:\CODING\zero_trust_security

# 2. Setup database deterministik (Hanya sekali di awal)
npm run db:setup
npm run db:seed

# 3. Jalankan seluruh service secara bersamaan (Gateway, Nilai, Transkrip, Frontend)
npm run start:all

# (Alternatif: Jalankan di 4 terminal PowerShell terpisah jika ingin melihat log masing-masing)
# Terminal 1: npm run dev:gateway      (Port 3000)
# Terminal 2: npm run dev:nilai        (Port 3001)
# Terminal 3: npm run dev:transkrip    (Port 3002)
# Terminal 4: npm run dev:frontend     (Port 5173)
```

5.2. Akun Demo Resmi & Device Terdaftar

Peran (Role)	Username	Password	Device ID Terdaftar	Keterangan Hak Akses
Mahasiswa 1	`mahasiswa1`	`PasswordMhs123!`	`dev-mhs1-thinkpad-01`	Ahmad Fauzi (NIM: 2207051001). Hanya melihat nilai & transkrip sendiri.
Mahasiswa 2	`mahasiswa2`	`PasswordMhs123!`	`dev-mhs2-macbook-01`	Bella Safitri (NIM: 2207051002). Akun pembanding uji anti-IDOR.
Dosen 1	`dosen1`	`PasswordDosen123!`	`dev-dosen1-dell-01`	Dr. Irfan Santoso, M.Kom. Mengampu Kelas A (Keamanan Informasi).
Dosen 2	`dosen2`	`PasswordDosen123!`	`dev-dosen2-lenovo-01`	Dr. Rina Maryana, M.T. Mengampu Kelas B (Basis Data Lanjut).
Admin	`admin1`	`PasswordAdmin123!`	`dev-admin1-secure-pc`	Siti Rahmawati, S.Kom. Hak baca seluruh transkrip & audit log PEP.

5.3. Skenario Uji 1: Mahasiswa (Ahmad Fauzi)

1. Buka browser di `http://localhost:5173`.
2. Pada form login, klik tombol cepat **Mahasiswa 1 (Ahmad Fauzi)**. Field username, password, dan Device ID akan terisi otomatis.
3. Klik ikon mata di samping kolom password untuk menguji fitur **Password Visibility Toggle**. Password akan tampil dalam format teks biasa, klik kembali untuk menyembunyikannya.
4. Klik tombol **Masuk ke Sistem**. Anda akan diarahkan ke Dashboard Mahasiswa.

5. Periksa tab **Nilai Perkuliahan**: tampil kartu ringkasan SKS dan daftar nilai semester mata kuliah Keamanan Informasi.
6. Pindah ke tab **Transkrip Akademik** di sidebar kiri: tampil ringkasan IPK dan total SKS lulus resmi.
7. Klik tombol **Keluar** di pojok kanan atas. Session dibersihkan seketika.

5.4. Skenario Uji 2: Dosen 1 (Dr. Irfan Santoso) & Finalisasi Nilai

1. Pada halaman login, klik tombol demo **Dosen 1 (Dr. Irfan)** lalu klik **Masuk ke Sistem**.
2. Perhatikan bahwa dosen HANYA melihat **Kelas A (Keamanan Informasi)** yang memang diampunya. Dosen 1 tidak dapat melihat kelas milik Dosen 2.
3. Pada baris mahasiswa Ahmad Fauzi, ubah nilai skor angka menjadi `95.00`, lalu klik tombol hijau **Simpan**. Nilai berhasil diperbarui.
4. Klik tombol **Finalisasi Nilai Kelas** di bagian kanan atas gradebook.
5. Akan muncul **Modal Konfirmasi Finalisasi** yang memperingatkan prinsip immutability Zero Trust.
6. Klik **Ya, Kunci & Finalisasi**. Sistem akan:
   - Mengunci status kelas menjadi **STATUS: FINAL**.
   - Kolom input nilai berubah menjadi terkunci (read-only) dan tombol simpan dinonaktifkan.
   - Service Nilai otomatis meminta Service Token dan menyinkronkan data ke Service Transkrip.
7. Logout dari akun Dosen.

5.5. Skenario Uji 3: Administrator (Pencarian Transkrip & Audit Trail)

1. Login menggunakan tombol demo **Administrator (Siti Rahmawati)**.
2. Pada tab **Transkrip Mahasiswa**:
   - Admin memiliki input pencarian NIM. Ketik NIM `2207051001` atau klik tombol pintas *Ahmad Fauzi*.
   - Transkrip Ahmad Fauzi tampil lengkap dengan nilai 95.00 (Huruf A) yang baru saja difinalisasi oleh Dosen 1. IPK terhitung 4.00.
   - Admin dapat memeriksa transkrip mahasiswa mana pun secara bebas sesuai hak verifikasi kelulusan.
3. Pindah ke tab **Audit Trail Log PEP** di sidebar:
   - Tampil tabel catatan log keamanan waktu-nyata untuk setiap keputusan evaluasi.
   - Setiap baris mencantumkan timestamp WIB, badge keputusan (`ALLOW` / `DENY`), Reason Code (misal: `AUTHENTICATED_ACCESS_ALLOWED`, `CLASS_FINALIZED_SYNCED`), path endpoint, subjek ID, dan Device ID.
   - Perhatikan bahwa tidak ada password atau token rahasia yang tercatat di tabel log.

5.6. Skenario Uji 4: Negative Security Testing (Pembuktian Pertahanan)

Skenario Serangan / Uji	Langkah Pengujian	Hasil & Respon Pertahanan
1. Uji Device Asing Tak Dikenal	Di halaman login, klik tombol merah **Uji Device Asing** (Device ID diganti menjadi `device-asing-ilegal-999`), lalu klik Masuk.	`DITOLAK (403)` Muncul banner merah: "*Akses Ditolak (Policy Deny) - Device ID tidak terdaftar untuk akun ini.*" Tercatat di audit log.
2. Uji Direct Service Bypass	Buka PowerShell dan jalankan perintah bypass langsung ke port internal service: `curl -i http://localhost:3001/nilai`	`DITOLAK (403)` Respon: `{"success":false,"message":"Forbidden: Direct service access denied"}`. Service menolak direct call.
3. Uji Anti-IDOR Mahasiswa	Login sebagai Mahasiswa 1, lalu coba panggil API transkrip milik Mahasiswa 2: `GET /transkrip/2207051002`	`DITOLAK (403)` Gateway menolak akses: mahasiswa dilarang membaca data akademik mahasiswa lain.
4. Uji Peniruan Service Sync oleh User	Kirim request `POST /transkrip/sinkron` menggunakan Bearer token milik user biasa (bukan token service).	`DITOLAK (403)` Gateway menolak keras: hanya token dengan claim `role: 'service'` yang diizinkan melakukan sinkronisasi.

5.7. Menjalankan Seluruh Pengujian Otomatis (Automated Test Suites)

Seluruh fungsionalitas dan skenario keamanan telah diotomatisasi ke dalam test runner modern. Jalankan perintah berikut di terminal:

```
# Menjalankan 41 Unit & Integration Tests (Vitest)
npm test

# Menjalankan 12 End-to-End User Journeys di Browser Asli (Playwright)
npx playwright test

# Reset database ke kondisi bersih
npm run db:seed
```

BAB 6: PANDUAN NASKAH DEMO & PRESENTASI SIDANG (6–9 MENIT)

Berikut adalah skenario dan naskah percakapan kata-demi-kata berdurasi 6 hingga 9 menit yang dirancang khusus untuk demonstrasi video atau presentasi langsung di depan dosen penguji:

Menit 00:00 – 01:15 • Pembukaan & Gambaran Umum Arsitektur

> *"Selamat pagi / siang Bapak/Ibu dosen penguji. Pada kesempatan kali ini, saya akan mendemonstrasikan implementasi Sistem Nilai Akademik PANDAKAD berbasis Zero Trust Security Architecture sesuai pedoman standar NIST SP 800-207.*
>
> *Sistem ini memegang tiga prinsip utama: Never Trust Always Verify, Least Privilege, dan Assume Breach. Di layar, dapat dilihat bahwa sistem berjalan di atas 3 proses server yang benar-benar terpisah: API Gateway pada port 3000 bertindak sebagai Policy Enforcement Point (PEP), Service Nilai pada port 3001, Service Transkrip pada port 3002, dan basis data PostgreSQL lokal pada port 5432."*

→ Tindakan Layar: Tampilkan diagram arsitektur dari `docs/architecture.md` atau tunjukkan 3 jendela terminal server yang sedang aktif.

Menit 01:15 – 02:45 • Autentikasi, Asymmetric JWT RS256 & Verifikasi Device

> *"Sekarang kita masuk ke aspek autentikasi. Zero Trust mensyaratkan verifikasi identitas dan konteks perangkat secara ketat. Di halaman login PANDAKAD, setiap pengguna wajib memasukkan kredensial dan Device ID.*
>
> *Pertama, saya demonstrasikan fitur kenyamanan input: password visibility toggle yang memungkinkan pengguna melihat dan menyembunyikan kata sandi. Sekarang saya login sebagai Mahasiswa 1 dengan perangkat terdaftar dev-mhs1-thinkpad-01. Login berhasil dan server menerbitkan access token RS256 berdurasi 10 menit.*
>
> *Sekarang mari kita uji prinsip 'Never Trust' dengan mencoba login menggunakan perangkat asing yang tidak terdaftar, yaitu device-asing-ilegal-999. Seperti yang terlihat di layar, sistem langsung menolak dengan status 403 Forbidden 'Device ID tidak terdaftar'. Keputusan penolakan ini langsung dicatat di log audit keamanan."*

→ Tindakan Layar: Login sebagai Mahasiswa 1, toggle password icon, logout, klik tombol merah 'Uji Device Asing', perlihatkan banner merah penolakan.

Menit 02:45 – 04:15 • Pertahanan Antar-Service & Isolasi Gateway Secret

> *"Berdasarkan prinsip Assume Breach, kita berasumsi bahwa penyerang mungkin telah menyusup ke dalam jaringan internal. Oleh karena itu, Service internal Nilai dan Transkrip tidak boleh mempercayai request mentah.*
>
> *Keduanya mewajibkan keberadaan header X-Gateway-Secret. Jika penyerang mencoba memanggil Service Nilai secara langsung di port 3001 menggunakan curl, service secara independen menolak dengan 403 Forbidden.*
>
> *Selain itu, jika klien luar mencoba menyuntikkan header rahasia palsu, middleware di Gateway secara paksa membersihkan dan menimpanya dengan secret resmi dari environment server."*

→ Tindakan Layar: Buka terminal, ketik `curl -i http://localhost:3001/nilai`, tunjukkan HTTP 403 Forbidden. Buka sekilas file `packages/service-nilai/src/middleware/verifyInternalAccess.ts`.

Menit 04:15 – 06:00 • Alur Dosen: Input Nilai, Time Window & Finalisasi Immutability

> *"Sekarang kita beralih ke akun Dosen 1, Dr. Irfan Santoso. Menerapkan prinsip Least Privilege, Dosen 1 hanya dapat melihat dan menilai Kelas A Keamanan Informasi yang memang diampunya.*
>
> *Sistem juga memeriksa kebijakan Window Waktu Akses: perubahan nilai hanya diizinkan pukul 07.00 hingga 21.00 WIB. Saya akan mengubah nilai mahasiswa Ahmad Fauzi menjadi 95.00 dan menyimpannya.*
>
> *Setelah nilai lengkap, dosen melakukan finalisasi. Saat tombol finalisasi diklik, antarmuka memunculkan modal konfirmasi yang menjelaskan bahwa nilai akan dikunci permanen. Setelah dikonfirmasi, status kelas berubah menjadi FINAL dan seluruh input nilai terkunci menjadi read-only demi menjamin integritas data akademik."*

→ Tindakan Layar: Login Dosen 1, ubah nilai Ahmad Fauzi jadi 95, simpan, klik Finalisasi Nilai Kelas, konfirmasi modal, tunjukkan badge hijau 'STATUS: FINAL' dan form terkunci.

Menit 06:00 – 07:30 • Service Token Antar-Layanan & Sinkronisasi Idempoten

> *"Ketika kelas difinalisasi, bagaimana transkrip mahasiswa terbit? Sesuai arsitektur Zero Trust, Service Nilai tidak memanggil database transkrip secara langsung dan tidak memanggil URL internal secara sembarangan.*
>
> *Service Nilai terlebih dahulu meminta Service Token ke Gateway via endpoint POST /auth/service menggunakan client ID dan secret internal. Token ini memiliki claim role: service dan masa berlaku 5 menit.*
>
> *Setelah mendapat token, Service Nilai memanggil POST /transkrip/sinkron melalui API Gateway. Gateway memastikan bahwa endpoint ini hanya boleh diakses oleh token role service. Service Transkrip menerima data dan menjalankan operasi UPSERT idempoten sehingga jika terjadi pengiriman ulang (retry), data transkrip tidak akan pernah terduplikasi."*

→ Tindakan Layar: Buka sekilas kode finalisasi di `packages/service-nilai/src/routes/nilaiRoutes.ts` (baris 270) dan `packages/service-transkrip/src/routes/transkripRoutes.ts` (baris 75).

Menit 07:30 – 08:30 • Verifikasi Transkrip Mahasiswa, Anti-IDOR & Administrator

> *"Sekarang mari kita login kembali sebagai Mahasiswa 1. Pada tab Transkrip Akademik, kita melihat mata kuliah Keamanan Informasi telah resmi masuk dengan skor 95.00, nilai huruf A, dan IPK kumulatif terhitung 4.00.*
>
> *Mahasiswa diproteksi dari celah IDOR (Insecure Direct Object Reference) sehingga tidak dapat melihat transkrip mahasiswa lain. Jika mahasiswa mencoba mengganti parameter NIM di URL, Gateway langsung menolak akses.*
>
> *Sebaliknya, jika kita login sebagai Administrator, Admin memiliki otorisasi Least Privilege untuk mencari dan memverifikasi transkrip seluruh mahasiswa untuk keperluan yudisium, namun Admin tidak memiliki hak untuk mengubah atau mengedit nilai perkuliahan."*

→ Tindakan Layar: Login Mahasiswa 1 → Tab Transkrip → Logout → Login Admin → Ketik NIM Ahmad Fauzi → Transkrip tampil rapi.

Menit 08:30 – 09:00 • Audit Trail PEP & Pembuktian 100% Automated Tests

> *"Sebagai penutup, kita buka tab Audit Trail Log PEP di dashboard Admin. Di sini tercatat seluruh jejak keputusan keamanan: waktu, subjek, endpoint, device, keputusan ALLOW atau DENY, serta alasan kebijakan secara transparan tanpa membocorkan data sensitif.*
>
> *Seluruh sistem ini telah dilengkapi automated testing komprehensif: 41 unit dan integration tests pada Vitest serta 12 end-to-end browser journeys pada Playwright yang seluruhnya lulus 100 persen. Demikian demonstrasi sistem Zero Trust PANDAKAD, terima kasih atas perhatian Bapak/Ibu dosen."*

→ Tindakan Layar: Tunjukkan tabel audit log Admin, lalu buka terminal dan jalankan `npm test` (tunjukkan 41 passed). Tunjukkan Playwright E2E report.

BAB 7: ANTISIPASI PERTANYAAN DOSEN & DEFENSE STRATEGY (FAQ)

Q1: Mengapa arsitektur ini harus dipecah menjadi 3 service terpisah dan tidak dijadikan satu aplikasi monolit Express saja?

Jawaban Kunci:
"Pemisahan proses adalah syarat fundamental dari standar **NIST SP 800-207**. Dalam Zero Trust, komponen *Control Plane* (Policy Enforcement Point & Policy Decision Point) harus dipisahkan dari *Data Plane / Resource Service*. Jika disatukan dalam satu monolit, kebocoran pada salah satu controller dapat mengompromikan seluruh sistem kontrol akses. Dengan memisahkan proses pada port 3000, 3001, dan 3002, kita dapat menerapkan batas kepercayaan (*trust boundary*) yang nyata, isolasi memori proses, serta membatasi hak akses basis data per layanan."

Q2: Mengapa kita menggunakan algoritma asimetris RS256 dan bukan simetris HS256 untuk tanda tangan JWT?

Jawaban Kunci:
"Pada algoritma simetris seperti HS256, rahasia (secret key) yang sama digunakan untuk membuat token dan memverifikasi token. Artinya, Service Nilai dan Service Transkrip harus memegang rahasia tersebut, sehingga jika salah satu service disusupi, penyerang dapat menerbitkan token palsu sendiri. Dengan algoritma asimetris RS256, **Private Key hanya dipegang oleh API Gateway**, sedangkan Service hilir hanya membutuhkan **Public Key**. Service hilir dapat memverifikasi keaslian token secara independen tanpa risiko mampu memalsukan token."

Q3: Mengapa token disimpan di memori dan bukan di LocalStorage browser?

Jawaban Kunci:
"Menyimpan token akses di `localStorage` merupakan celah keamanan yang sangat rentan terhadap serangan *Cross-Site Scripting (XSS)*, karena skrip JavaScript berbahaya dapat membaca isi `localStorage` dan mencuri token. Pada sistem kami, token akses disimpan secara aman di dalam memori React state (yang hilang saat tab ditutup), sedangkan Refresh Token dikelola menggunakan sesi berbasis server dengan rotasi token di basis data."

Q4: Apa yang dimaksud dengan 'Idempotent Sync' pada integrasi Service Nilai ke Service Transkrip?

Jawaban Kunci:
"Idempotensi menjamin bahwa suatu operasi yang dieksekusi berulang kali akan menghasilkan kondisi akhir yang sama persis tanpa efek samping negatif. Ketika jaringan mengalami gangguan (timeout) saat dosen melakukan finalisasi, Service Nilai mungkin melakukan pengiriman ulang (retry). Di Service Transkrip, kami menggunakan klausul SQL `ON CONFLICT (student_id, class_id) DO UPDATE` sehingga data nilai diperbarui secara akurat dan tidak menciptakan duplikasi baris transkrip mahasiswa."

Q5: Mengapa verifikasi X-Device-ID dilakukan di Gateway dan apa batasannya?

Jawaban Kunci:
"Verifikasi `X-Device-ID` memastikan bahwa request hanya diterima jika berasal dari perangkat yang terikat (bound) pada akun pengguna tersebut di basis data. Batasannya adalah header HTTP dapat dipalsukan jika penyerang mengetahui ID perangkat yang sah. Namun, dalam sistem Zero Trust kami, header ini dievaluasi secara simultan bersama kredensial autentikasi, masa berlaku token, dan window waktu (*multi-factor context*) sehingga penyerang tidak dapat menembus sistem hanya dengan memalsukan salah satu atribut."